

INFORMATION CLASSIFICATION POLICY

Tumaini Capital Ltd | ISMS-POL-005 | ISO/IEC 27001:2022 — Annex A 5.12 & 5.13 | Fictional case study

Document Title	Information Classification Policy	Document ID	ISMS-POL-005
Version	1.0	Status	<i>DRAFT — Pending Approval</i>
Author	Head of Risk & Compliance (ISMS Lead)	Date	June 2026
Approved By	ISMS Lead & CEO	Next Review	June 2027
Related Documents	ISMS-POL-001 (Information Security Policy), ISMS-POL-004 (Acceptable Use & BYOD Policy), DPA 2019, ISMS-DOC-006 (Risk Assessment)		

1. PURPOSE

This policy establishes Tumaini Capital's information classification scheme and defines the handling requirements for each classification level. It ensures that information is protected in proportion to its sensitivity, in compliance with the Data Protection Act, 2019, and in a manner consistent with the risk treatment decisions documented in the ISMS risk register.

Every piece of information created, received, or processed by Tumaini Capital has an inherent sensitivity level. This policy makes that implicit level explicit, so that every member of staff knows how to handle the information they work with.

2. SCOPE

This policy applies to all information in any format — digital files, emails, printed documents, verbal communications, and system-generated records — created, processed, stored, or transmitted by Tumaini Capital staff, contractors, or systems within the defined ISMS scope. It applies at both the Nairobi and Kisumu offices and to remote working contexts.

3. CLASSIFICATION SCHEME

Tumaini Capital uses four classification levels. Every piece of information must be assigned to one of these levels. Where uncertainty exists, the higher classification level shall apply.

Level 1 — PUBLIC

Information intended for, or suitable for, unrestricted public disclosure. Disclosure of this information presents no risk to Tumaini Capital or its customers. Examples include: the company website and marketing materials, the mobile app listing and USSD product descriptions, published interest rates and loan product terms, job postings and press releases.

Level 2 — INTERNAL

Non-sensitive business information for use within Tumaini Capital. Unauthorized external disclosure is undesirable but would cause limited harm. Examples include: internal meeting minutes and action logs, process documentation and operational guides, internal announcements and all-staff communications, general business correspondence not involving sensitive data.

Level 3 — CONFIDENTIAL

Sensitive business or customer information requiring controlled access. Unauthorized disclosure could harm customers, damage Tumaini Capital's reputation, or create regulatory risk. Examples include: customer loan application records and credit decisions, M-Pesa disbursement and repayment transaction records, staff personal

data (payroll, HR records, performance reviews), internal financial reports and management accounts, contractual agreements and supplier terms.

Level 4 — RESTRICTED

Highest sensitivity. Unauthorized disclosure would likely cause significant harm to customers, create legal liability, or critically compromise Tumaini Capital's operations. This classification includes all personal data as defined under the Data Protection Act, 2019 that carries a high risk of harm if disclosed. Examples include: customer KYC documents (copies of national IDs, passports, bank statements, payslips), all AWS credentials, API keys, and system passwords, board meeting minutes and legal correspondence, ISMS risk register and internal audit findings, credit bureau data and raw credit scores.

Restricted information shall always be treated as if it is the most sensitive information the organization holds. When in doubt, classify as Restricted.

4. HANDLING REQUIREMENTS

The table below defines the minimum handling requirements for each classification level. More restrictive handling is always permitted. Less restrictive handling requires written approval from the ISMS Lead.

Handling Requirement	PUBLIC	INTERNAL	CONFIDENTIAL	RESTRICTED
Storage	Any approved storage	Company systems only	Company systems; no personal cloud	Encrypted company storage only; access logged
Email transmission	Freely	No external forwarding without approval	Encrypted or secure portal; no personal email	Encrypted only; never via personal email or messaging
WhatsApp Business	Freely	Internal use only	Must not contain KYC or loan data	Never via WhatsApp or personal messaging
Printing	Freely	Collect from printer promptly	Restricted printer; collect immediately; secure disposal	Printed only when essential; logged; shredded after use
Sharing externally	Freely	Prior approval required	Signed NDA or data sharing agreement required	ISMS Lead written approval; legal basis documented
Storage on personal devices	Yes	Avoid where possible	Not permitted	Never permitted
Disposal	Standard bin	Recycle bin / delete	Shred (paper); secure delete (digital)	Cross-cut shred (paper); certified wipe (digital)
Access control	None	Role-based standard access	Need-to-know; manager approval required	Named individuals only; ISMS Lead authorization required

5. LABELLING REQUIREMENTS

Information shall be labelled with its classification level to ensure consistent handling. Labelling requirements by format are as follows:

5.1 Documents (Word, PDF, presentations)

- Classification level shall appear in the header or footer of every page, for Confidential and Restricted documents.
- The document title page or cover shall include the classification level prominently.
- File names should reflect the classification where practical (e.g. RESTRICTED_KYC_Review_June2026.pdf).

5.2 Email

- Emails containing Confidential information should include [CONFIDENTIAL] at the start of the subject line.
- Emails containing Restricted information must include [RESTRICTED] at the start of the subject line and must not be forwarded without the sender's explicit approval.

5.3 Physical documents

- Printed Confidential and Restricted documents shall be marked with their classification level in the header or footer.
- Confidential and Restricted documents must not be left unattended on desks or in shared areas.

5.4 Google Drive and shared storage

- Folders containing Confidential or Restricted information shall be named to reflect the classification (e.g. [RESTRICTED] KYC Archive).
- Folder and file access permissions shall be set to the minimum required. Restricted folders shall require explicit individual access grants reviewed quarterly.

6. ROLES AND RESPONSIBILITIES

- Information owners (typically the Head of Risk & Compliance for customer data, the Head of Engineering for system credentials) are responsible for classifying information under their remit and ensuring appropriate handling controls are applied.
- All staff are responsible for handling information in accordance with its classification level, applying labels correctly, and escalating uncertainty to their line manager or the ISMS Lead.
- The ISMS Lead is responsible for maintaining this policy, providing guidance on classification decisions, and reviewing the scheme annually.

7. DECLASSIFICATION AND RECLASSIFICATION

Information may be declassified or reclassified where the circumstances that justified the original classification have changed. For example, a confidential internal report may become Public once formally approved for external release. Reclassification decisions for Confidential and Restricted information require written approval from the information owner and must be documented. Reclassification of Restricted information also requires ISMS Lead sign-off.

8. PERSONAL DATA AND THE DATA PROTECTION ACT, 2019

Any information that constitutes personal data under the Data Protection Act, 2019 must be classified as Confidential at minimum. Information that constitutes sensitive personal data under the Act — including financial data, identity documents, and credit information — must be classified as Restricted. Classification as Restricted does not discharge Tumaini Capital's obligations under the Act; data protection requirements apply in addition to and independently of this classification scheme.

9. POLICY REVIEW

This policy shall be reviewed annually, following a significant change to the types of information processed by Tumaini Capital, or following a change to applicable data protection legislation or regulatory guidance.

Role	Name & Signature	Date
Head of Risk & Compliance / ISMS Lead		
Chief Executive Officer (Approver)		